

Security: Introduzione

A horizontal yellow brushstroke with a textured, painterly appearance, extending across the width of the slide below the title.

Definizioni (I-a)

❑ SubjectFisico

❑ Utente / Organizzazione **esterna** al calcolatore

❑ **Subject**: $\approx$ Identificatore testuale di un SubjectFisico

❑ **Stringa** esistente **all'interno** del calcolatore

❑ Formato e significato **dipende** dall'applicazione



SubjectFisico ← - - - - - ► Subject

```
bartoli.alberto@gmail.com  
bartoli.alberto  
5943  
BRTLRT31S21Z623R  
3298873471  
...
```



Definizioni (I-b)

- ❑ **Subject**: $\approx$ Identificatore testuale di un SubjectFisico
 - ❑ **Stringa** esistente **all'interno** del calcolatore
 - ❑ Formato e significato **dipende** dall'applicazione
 - ❑ Caso frequente: **DNS name**



```
www.units.it  
esse3.units.it  
...
```



SubjectFisico $\leftarrow$ ----- $\rightarrow$ Subject

Definizioni (II-a)

❑ Sequenza di byte: **B**

❑ Messaggio

❑ Applicativo (SMTP, POP, HTTP, DNS,...)

❑ Pacchetto

❑ Frame

❑ File

❑ Email

❑ ...

B

07	F2	AE	44	56	A4	B1	66	51	...
----	----	----	----	----	----	----	----	----	-----

Definizioni (II-b)



- ❑ Sequenza di byte: B
- ❑ Spesso **"creata"** / **"proviene"** da un **Subject**
 - ❑ Associazione Esplicita
 - ❑ Messaggio email contiene indirizzo mittente
 - ❑ File ha uno username proprietario
 - ❑ ...
 - ❑ Associazione Implicita
 - ❑ HTTP request in sessione autenticata
 - ❑ POP request in sessione autenticata
 - ❑ ...

Definizioni (II-c)



- ❑ Sequenza di byte: B
- ❑ Spesso "**creata**" / "**proviene**" da un **Subject**
 - ❑ Associazione Esplicita
 - ❑ ...
 - ❑ Pacchetto ha **indirizzo IP mittente**
 - ❑ Indirizzo IP è un Subject
 - ❑ **Non** necessariamente / facilmente associato a SubjectFisico
 - ❑ ...

Definizioni (III)



Network
Internet
Memory pen
CD
Corriere (TNT, Bartolini, Poste)

...

- ❑ Nello **spazio**
- ❑ Ma anche nel **tempo**
(file a distanza di mesi/anni)

Scenario (I)

- ❑ **Attacker** nel **canale di comunicazione** ("Network attacker")
 - ❑ **Osserva / Modifica / Fabbrica**
 - ❑ Qualsiasi sequenza di byte in qualsiasi istante



- ❑ Desideriamo "**proprietà di sicurezza**" su **B**

Scenario (II)



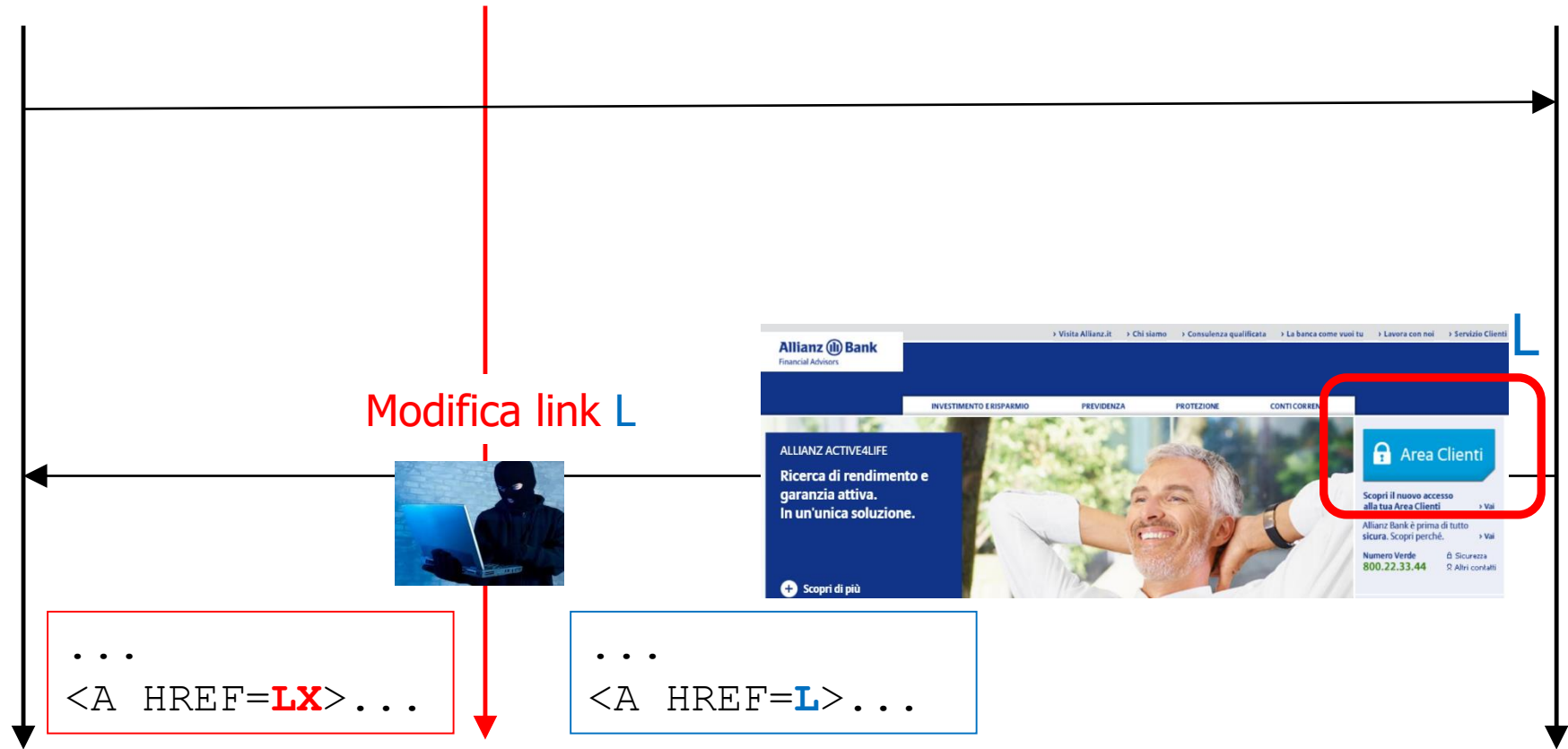
- ❑ **Attacker** nel **canale di comunicazione** ("Network attacker")
 - ❑ **Osserva / Modifica / Trasmette**
 - ❑ Qualsiasi messaggio in qualsiasi istante

- ❑ Network Attacker deve essere considerato un **dato di fatto**
 - ❑ Pensare a **cosa** può fare (conseguenze)
 - ❑ Non a **come** può esistere

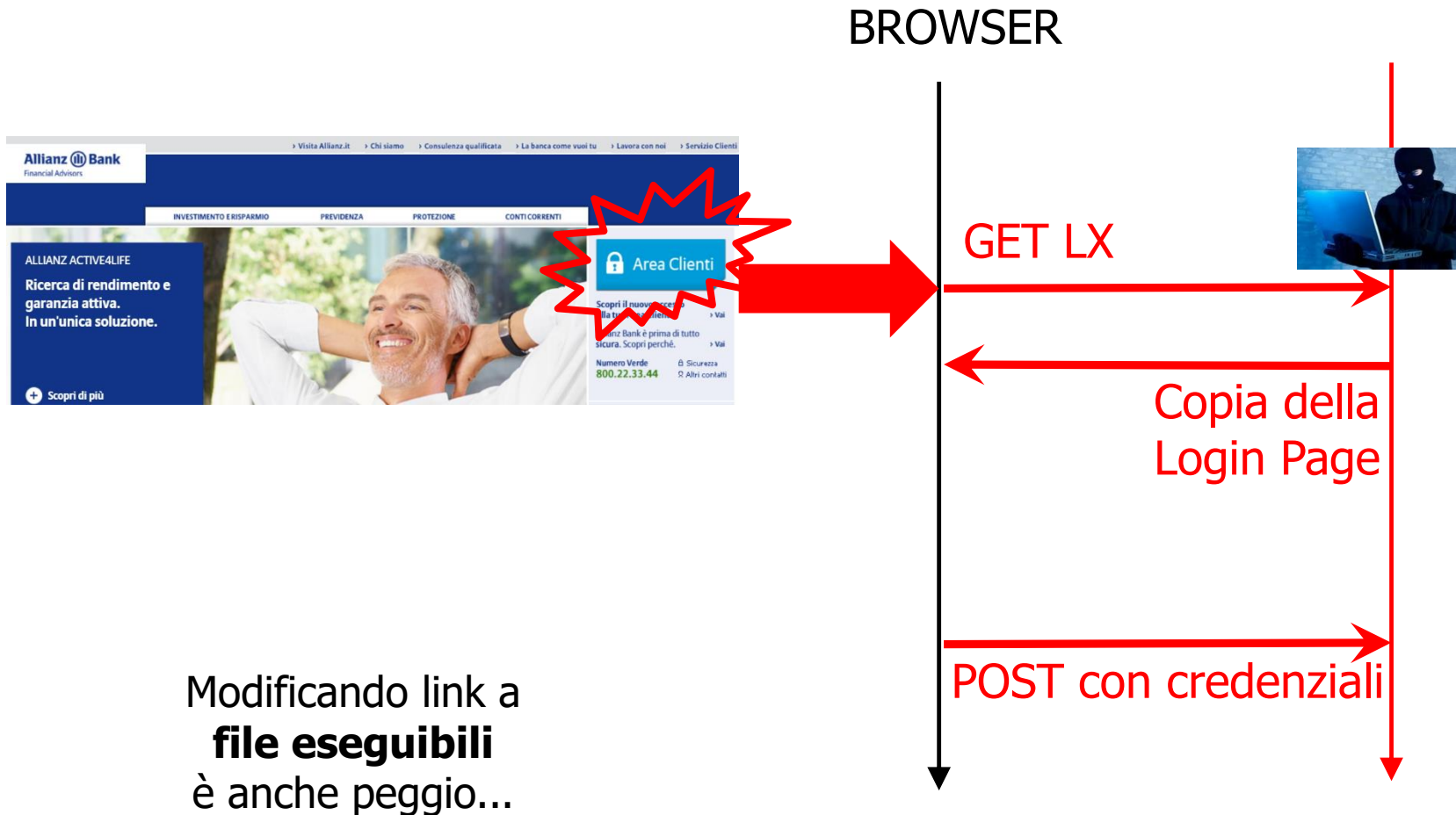
- ❑ Considerare entrambi i problemi confonde le idee

Cosa può fare: HTTP Injection (I-a)

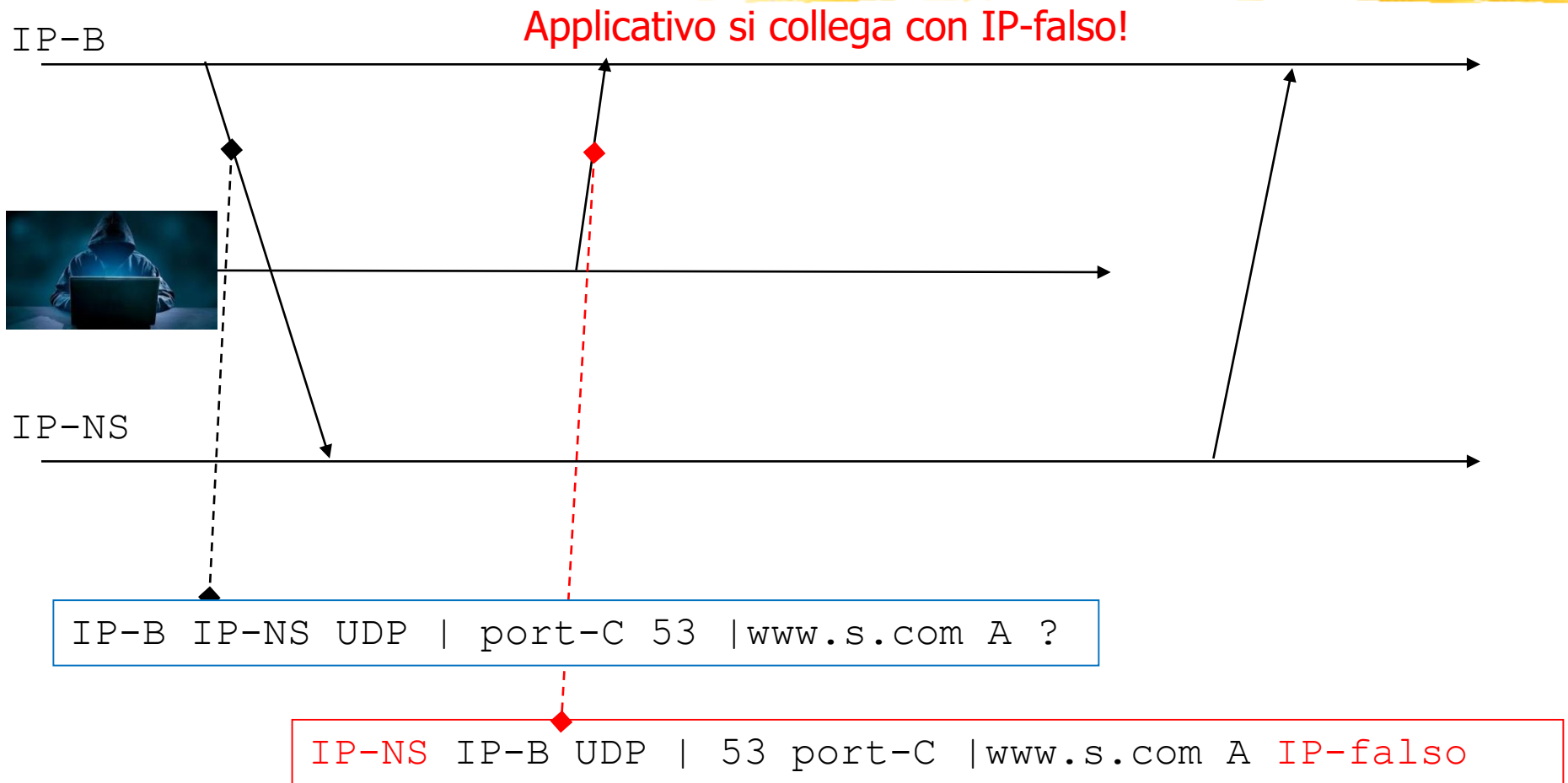
BROWSER



Cosa può fare: HTTP Injection (I-b)



Cosa può fare: DNS spoofing



Perché è importante? (I)



- ❑ Sistemisti Access point
- ❑ Sistemisti Router
- ❑ Sistemisti Name Server

- ❑ Sistemisti ISP

- ❑ Sorveglianza imposta a ISP da forze statali
 - ❑ Polizia autorizzata da Autorità Giudiziaria (può essere "giusto" o meno)
 - ❑ Polizia anche non autorizzata da Autorità Giudiziaria (idem)
 - ❑ Servizi di sicurezza
 - ❑ ...

Perché è importante? (II)



- ❑ Reti **WiFi Open**
- ❑ Reti **WiFi Personal in ambienti non Personal**
 - ❑ Alberghi, Bar, Ristoranti con stessa password WiFi per tutti
- ❑ Precedono alcuni esempi delle numerosissime cose che può fare un network Attacker

Nota bene



- ❑ **Attacker** nel **canale di comunicazione** ("Network attacker")
 - ❑ **Osserva / Modifica / Fabbrica**
 - ❑ Qualsiasi messaggio in qualsiasi istante
- ❑ Il **canale** è una entità **astratta**
 - ❑ Astratto = Generale
 - ❑ Astratto != Inutile
- ❑ **Non** è "solo Internet"

Cosa può fare: Green pass

Azienda Sanitaria



Modifica



Fabbrica

Cosa può fare: GPS



Modifica



Cosa faremo



1. Definizione proprietà di sicurezza

- ❑ **Nessun** protocollo visto finora le fornisce
- ❑ NetworkAttacker può eliminarle con "poca" difficoltà

2. Strumenti matematici

- ❑ Visti come black box

3. Protocolli / tecniche per fornire le proprietà di sicurezza

- ❑ NetworkAttacker non può eliminarle
(o le elimina con "costo altissimo")

- ❑ Trattazione **molto** semplificata

Semplificazione nostra

□ Subject:

1. Username per gli **utenti**

2. DNS name per i **server**

Non consideriamo altri casi

□ SubjectFisico: quello "ovvio" (a cui ci fa pensare il Subject)



□ Quello che diremo è generale: serve solo per fissare le idee

Garanzie di Sicurezza



Authentication

- ❑ Sequenza **B** costruita da Subject **S**
(informazione esplicita o implicita)

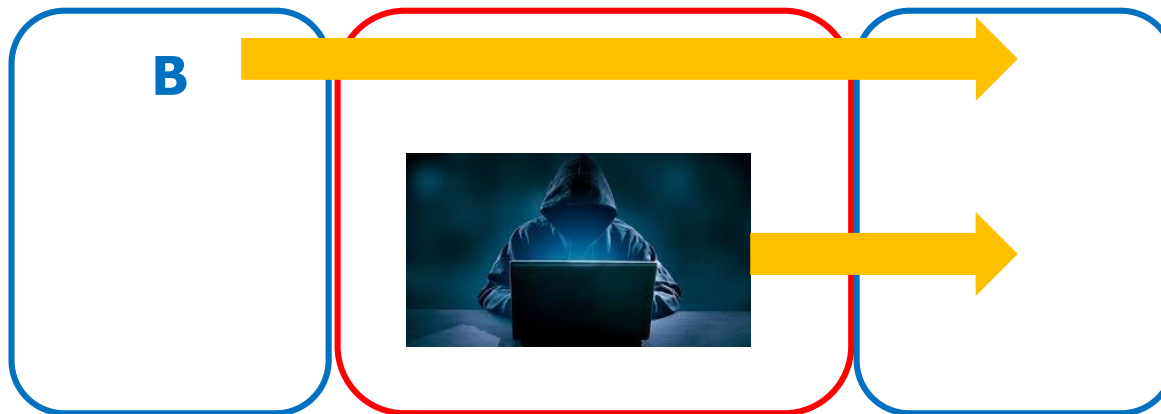
```
07 F2 AE 44 56 A4 B1 ... "S" ... 66 51 ...
```

- ❑ Garanzia che **B** è stata **veramente** generata da **S**

Hmmm...

Protocolli applicativi (I-a)

- ❑ Risposte HTTP
- ❑ S = web server sito Internet banking
- ❑ Richieste HTTP
- ❑ S = titolare del conto corrente



Hmmm...

Protocolli applicativi (I-b)



- ❑ Login page
- ❑ S = Web server esse3 / Facebook / Bitcoin wallet / Unicredit / ...
- ❑ +OK mail server ready
- ❑ S = mail server
- ❑ `www.unicredit.it` A `80.84.97.14`
- ❑ S = name server
- ❑ ...

Hmmm...

Protocolli livelli più bassi



- ❑ **Frame Ethernet** con Eth-src = **Eth-x**
 - ❑ Veramente generato da nodo con indirizzo Eth-X?

- ❑ **Messaggio ARP** con ARP-src = **Eth-x, IP-x**
 - ❑ Veramente generato da nodo con indirizzi Eth-X e IP-x?

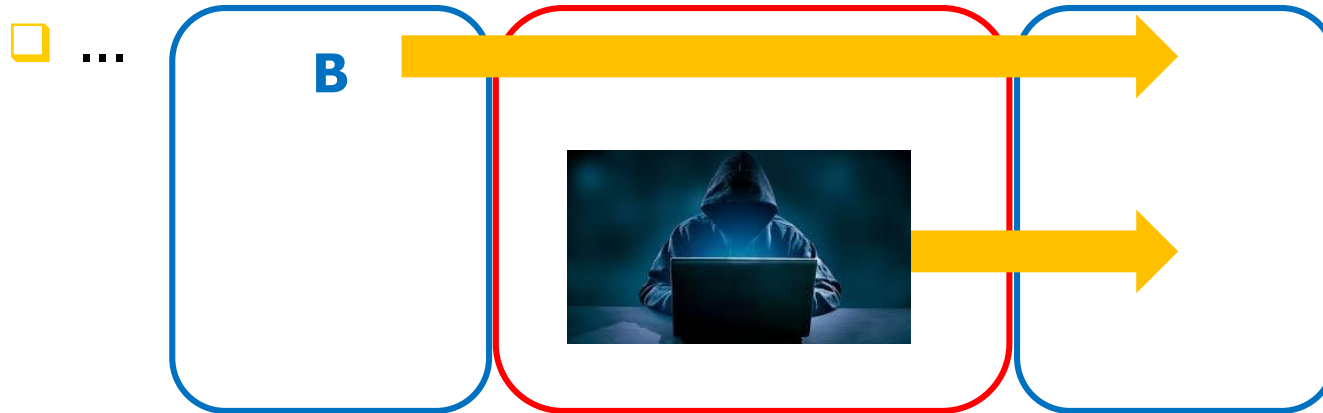
- ❑ **Pacchetto IP** con IP-src = **IP-x**
 - ❑ Veramente generato da nodo con indirizzo IP-x?

- ❑ **Connessione TCP** con nodo **IP-X**
 - ❑ All'altra estremità c'è veramente il nodo con indirizzo IP-X?

Hhmmm...

Dati (III)

- ❑ Messaggio Email in cui sono convocato dal Real Madrid
- ❑ S = Carlo Ancelotti
- ❑ File con esiti della provetta di Reti di Calcolatori
- ❑ S = sapete già



Riservatezza (Secrecy / Confidentiality)



- Garanzia che **B** è "**comprensibile**" solo a insieme di Subject "autorizzati"

Hmmm...



☐ Messaggi

- ☐ HTTP Request con **credenziali** di autenticazione
- ☐ Traffico SMTP con **email**
- ☐ Traffico POP con **credenziali** ed **email**
- ☐ Traffico DNS con **nomi di siti** che non vorremmo rivelare

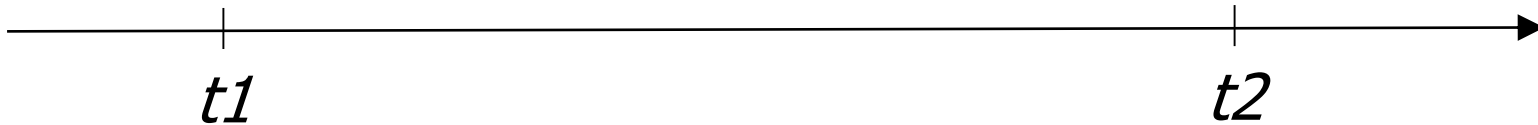
☐ Dati

- ☐ File contenente contabilità di tangenti pagate a politici
- ☐ File contenente immagini XXX
- ☐ File contenente intercettazioni telefoniche o ambientali
- ☐ Disco di portatile contenente dati sensibili (sanitari o altro)
- ☐ Memoria di uno smartphone
- ☐ ...

Integrity

□ **B** costruita a istante $t1$ ed **usata** a istante $t2$

□ Garanzia che **B**($t1$) = **B**($t2$)



□ **Luogo** di costruzione può essere **diverso** da luogo di verifica

□ **Subject** che costruisce può essere **diverso** da Subject che verifica

Hhhmmm...

Protocolli



- ❑ Pagina web contenente link critico (login page, file eseguibile)
 - ❑ t1 = invio dal web server
 - ❑ t2 = arrivo al browser

- ❑ Pagina web contenenti risultati di ricerca
 - ❑ t1 = invio da Google
 - ❑ t2 = arrivo al browser

- ❑ Risposta DNS
 - ❑ t1 = invio da parte del name server
 - ❑ t2 = arrivo al client DNS

Hhhmmm...

Dati



☐ Email

- ☐ t1 = invio dal mail client sender
- ☐ t2 = arrivo al mail client receiver

☐ Verbale esame

- ☐ t1 = superamento esame
- ☐ t2 = consegna della domanda di laurea

☐ Referto medico

- ☐ t1 = costruzione del referto
- ☐ t2 = analisi in procedimento giudiziario

☐ Intercettazione telefonica / ambientale

- ☐ t1 = captazione del dato
- ☐ t2 = analisi in procedimento giudiziario

Protocolli visti finora



- Integrity
- Secrecy
 - Nessuno le garantisce
- Authentication
 - Nessuno garantisce autenticazione del Server
 - Alcuni garantiscono autenticazione del **solo Client**
 - Ma in scenario "NetworkAttacker **non** c'è"

Altre proprietà importanti (che non vediamo)



- ❑ Non repudiation (non puoi negare di averlo detto)
- ❑ Plausible deniability (puoi dimostrare che non l'hai detto)
- ❑ Timestamp (esiste ad un istante specificato)
- ❑ **Availability** (il sistema funziona)
- ❑ ...
- ❑ ...

NON sono necessità "di Internet"



- ❑ Autenticazione
- ❑ Segretezza
- ❑ Integrità
- ❑ Non ripudio
- ❑ Timestamp
- ❑ ...

PER

- ❑ Comunicazioni
- ❑ Documenti

❑ **Tempo**

- ❑ Roma caput mundi
- ❑ Medioevo
- ❑ Anni Sessanta
- ❑ ...

❑ **Contesto**

- ❑ Attività finanziarie
- ❑ Attività commerciali
 - ❑ Consegna merci in un porto lontanissimo
- ❑ Guerre
 - ❑ Informazioni ricevute da una spia
 - ❑ Contatti con inviati di un esercito alleato
 - ❑ Ordini ricevuti dal quartier generale
- ❑ ...

Soluzioni PRIMA di Internet



- ❑ Miriadi di soluzioni diverse
- ❑ Dipendenti dal contesto

- ❑ Esempio per ottenere Non Ripudio
 - ❑ Firma su cartaceo
 - ❑ Timbro su ceralacca

- ❑ Elementi frequenti:
 - ❑ Contatto **fisico** tra **SubjectFisici**
 - ❑ Comunicazioni / documenti **cartacei**

Importantissimo

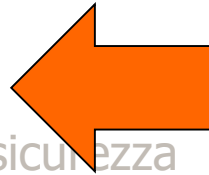


- ❑ Assumiamo la **perfezione** in:
 - ❑ Algoritmi
 - ❑ Protocolli
 - ❑ Software
 - ❑ Procedure operative

- ❑ In pratica, queste ipotesi spesso **non** sono verificate
⇒ Cadono tutte le proprietà di sicurezza
 - 1. "Non perfezione"
 - 2. NetworkAttacker può eseguire programmi su nodo target
 - 3. Diventa **Node**Attacker
 - 4. Meccanismi difensivi tengono conto solo del NetworkAttacker

Strumenti matematici

1. Descrizione proprietà di sicurezza
2. **Strumenti matematici** u(come black box)
3. Protocolli/tecniche per fornire le proprietà di sicurezza



- ☐ Crittografia a "chiave privata"
- ☐ Crittografia a "chiave pubblica"
- ☐ Message Authentication Code
- ☐ Firma Digitale
- ☐ **Per il momento non chiedersi come si usano in pratica**
(altrimenti non si capiscono)

Importantissimo

NON risolvono “automaticamente” i problemi di security !

I do not know to whom should be credited the important truth
“Whenever anyone says that a problem is easily solved by
cryptography, it shows that he doesn’t understand it”.

Roger Needham

quasi equivalente a
(quasi)



Crittografia chiave privata

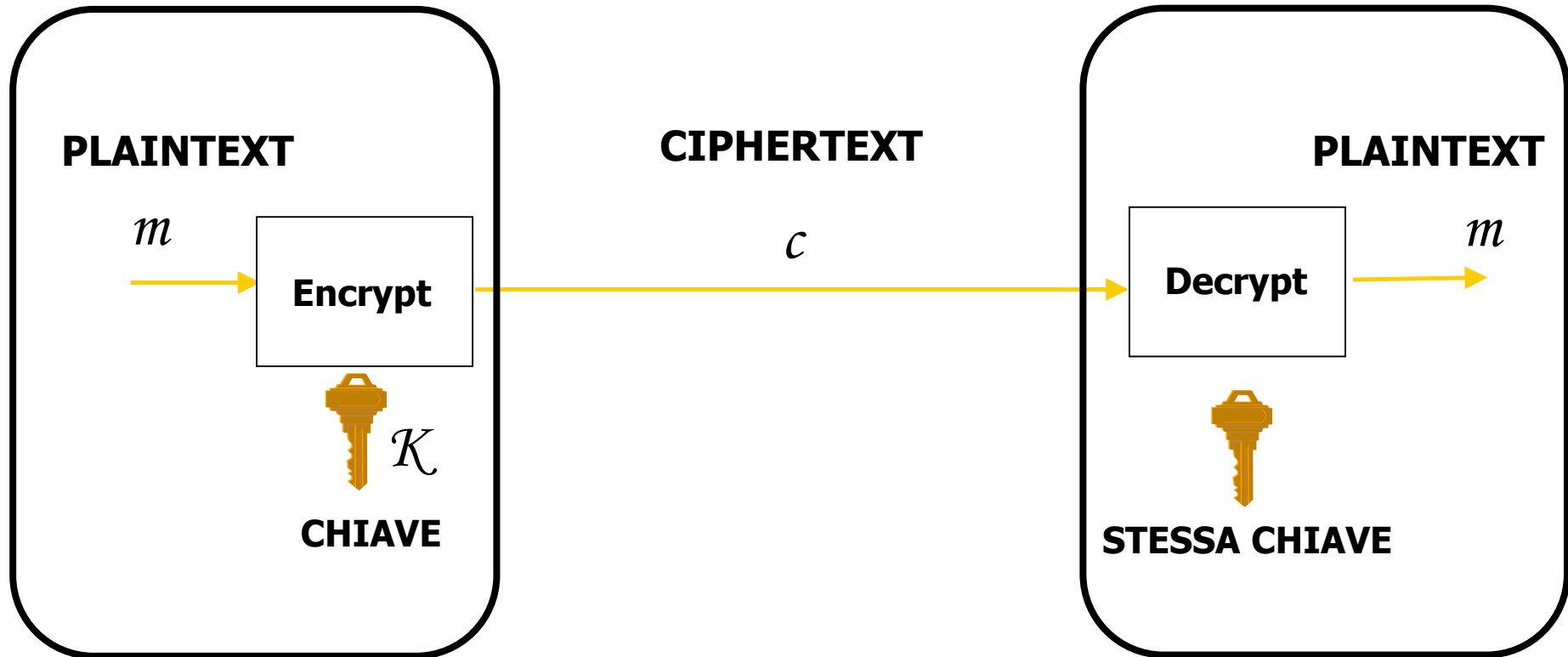


Scenario



- ❑ Condividono **chiave K**
(numero naturale "molto grande")
- ❑ Utilizzano K per garantire
 - ❑ **Secrecy**

Crittografia a chiave privata (I)



Crittografia a chiave privata (II)

□ Notazione:

- Critto m con chiave K : $\text{Encrypt}_K(m)$
- Decritto c con chiave K : $\text{Decrypt}_K(c)$
- Spesso i due algoritmi sono identici (ma non è necessario)

$$\begin{array}{c} \xleftarrow{c} \\ \square \text{Decrypt}_{KD}(\text{Encrypt}_{KE}(m)) = m \\ \Leftrightarrow \\ KD = KE \end{array}$$

- "Per risalire al plaintext bisogna conoscere la chiave"

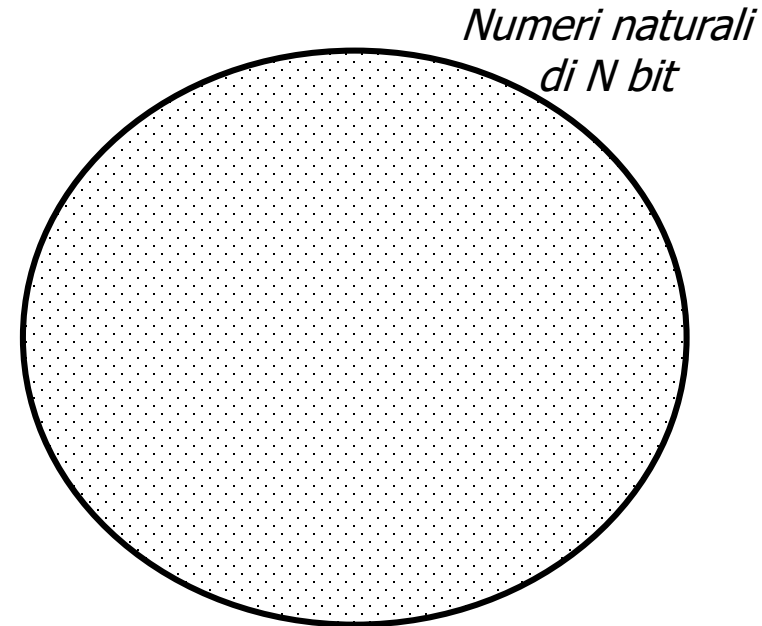
Insieme delle chiavi

- ❑ Ogni sequenza di N bit è una possibile chiave
- ❑ Numero chiavi possibili = 2^N
- ❑ Il valore N dipende dall'algoritmo

$N = 8 \Rightarrow 256$ chiavi possibili

$N = 32 \Rightarrow$ Più di 4 miliardi di chiavi possibili

$N = 64 \Rightarrow$ Più di $16 * 10^{18}$ chiavi possibili

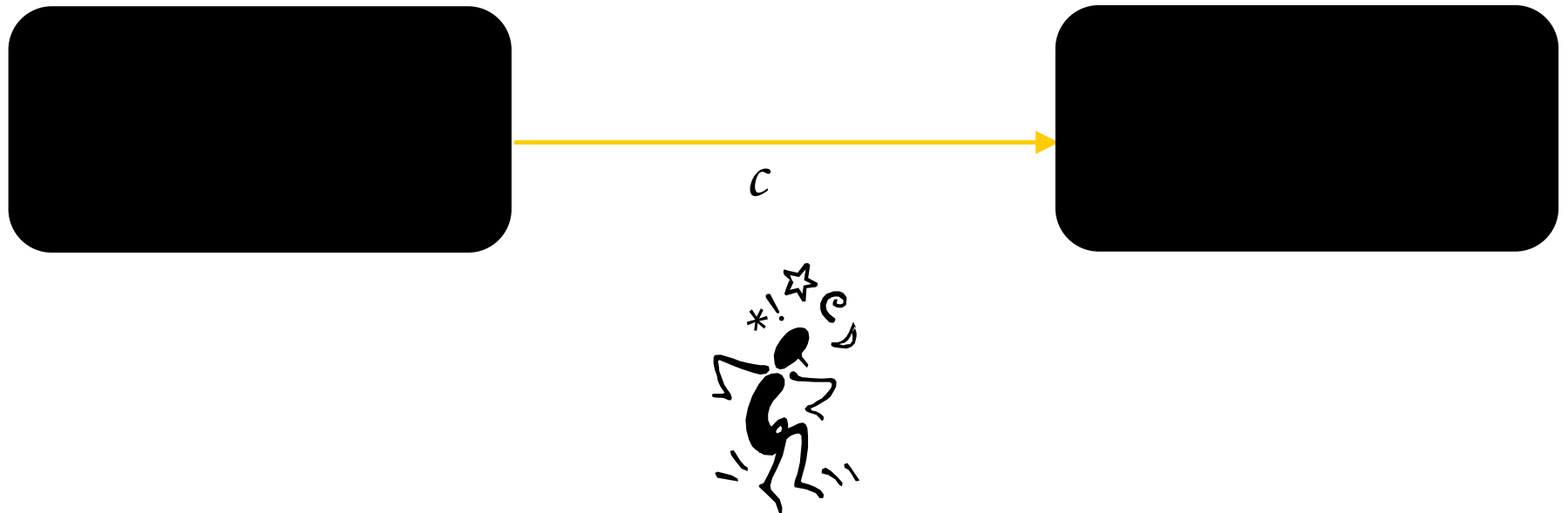


Network Attacker: Scenario



- ❑ A e B usano una chiave **K** di N bit
- ❑ Il **solo** segreto è **K**: Network Attacker **conosce tutto**
 1. Algoritmo di crittografia utilizzato
 2. Lunghezza chiave N
 3. Ciphertext c
- ❑ Attaccante desidera:
 - ❑ Indovinare **K**
oppure
 - ❑ Indovinare m per quel particolare c
(più semplice che indovinare K: "decrittare un solo messaggio")

Proprietà fondamentale (in parole povere)



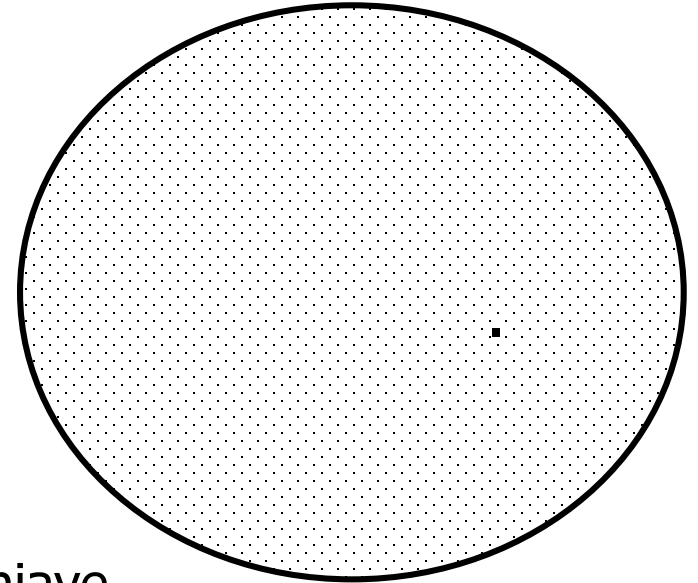
❑ **PRATICAMENTE IMPOSSIBILE:**

- ❑ Ciphertext $\rightarrow$ K
- ❑ Ciphertext $\rightarrow$ Plaintext

Attacco 1: brute-force

❑ Ricerca esaustiva

- ❑ Attaccante prova **tutte** le chiavi
- ❑ Quando ciphertext decrittato ha contenuto "sensato" allora ha trovato la chiave



Algoritmi moderni: “Sono troppe”

- Algoritmi moderni:
 - Permettono di usare N “sufficientemente grande”
 - Al punto da rendere la ricerca esaustiva “praticamente inapplicabile”
- Il valore adeguato di N dipende dal “momento storico”

<https://www.keylength.com>

1 Reference for the comparison

You can enter the year until when your system should be protected and see the corresponding key sizes or you can enter a key/hash/group size and see until when you would be protected.

Enter a year:

2017

Method	Date	Symmetric
[1] Lenstra / Verheul ?	2015	82
[2] Lenstra Updated ?	2015	78
[3] ECRYPT II	2013 - 2020	96
[4] NIST	2011 - 2030	112
[5] FNISA	2010 - 2020	100

Attacco 2: Crittoanalisi (I)

1. Attaccante riesce ad estrarre dal ciphertext **informazione** su K
2. ...

- ❑ Esempio (inventato)

- ❑ Algoritmo crittografia

+

- ❑ Il plaintext è HTTP

+

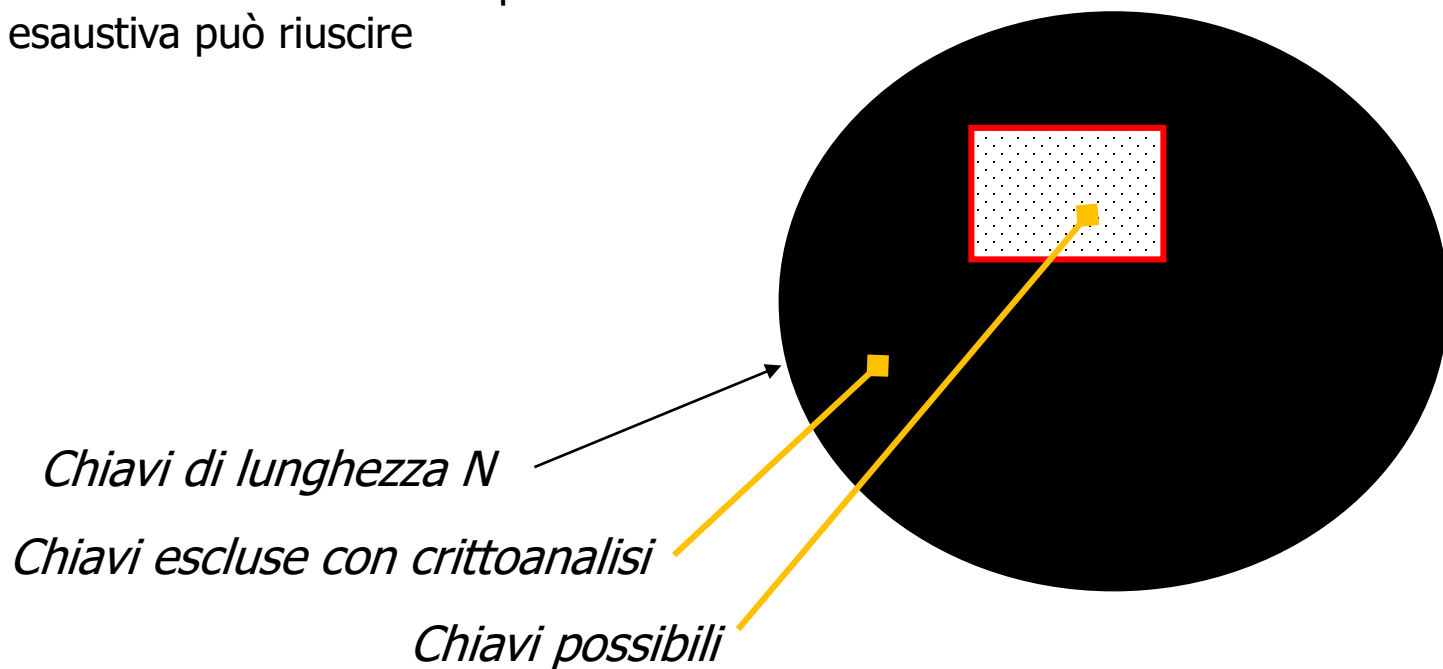
- ❑ Una stringa di ciphertext contiene un numero di 1 che è multiplo di sette e dopo tre 1 consecutivi ci sono sempre due 0 consecutivi



- ❑ K non può avere cinque 1 consecutivi

Attacco 2 (Crittanalisi) (II)

1. Attaccante riesce ad estrarre dal ciphertext **informazione** su K
2. Attaccante riesce ad **escludere** molte chiavi
3. Esegue ricerca esaustiva **solo** sulle chiavi rimaste
 - Se l'insieme rimasto è sufficientemente piccolo
Allora ricerca esaustiva può riuscire



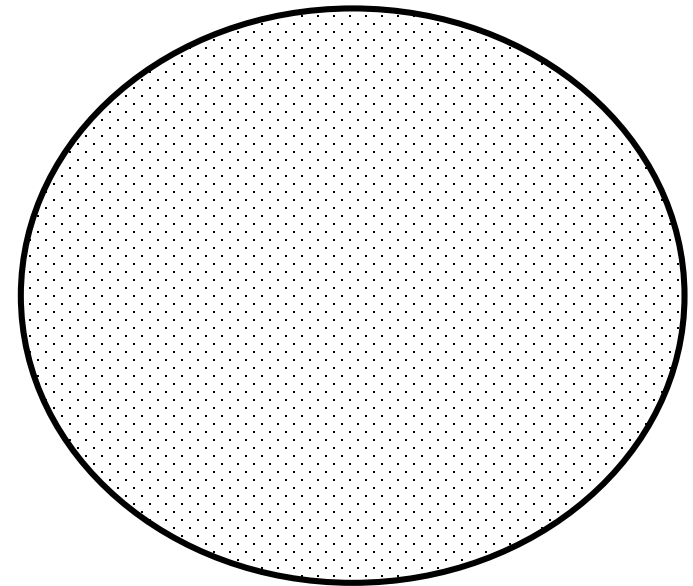
Algoritmi moderni: "Devo provarle tutte"

Proprietà degli algoritmi "moderni":

❑ Ciphertext non fornisce **nessuna informazione** su key / plaintext

❑ Conseguenza:

- ❑ Impossibile escludere chiavi a priori
- ❑ Necessaria ricerca esaustiva su tutto l'insieme



Enigma (I)

- ❑ Cleartext = Sequenza di tasti
- ❑ Ciphertext = Sequenza di luci
- ❑ $K \approx$ posizione iniziale rotori + collegamento alcuni cavi
- ❑ Numero chiavi possibili $\approx 15 * 10^{180}$



search "enigma encryption online"

Enigma (II)



- ❑ L'algoritmo implementato in Enigma:
 - ❑ Aveva la proprietà P1 ("sono troppe")
 - ❑ **Non aveva** la proprietà P2 ("devo provarle tutte")

Gli inglesi:

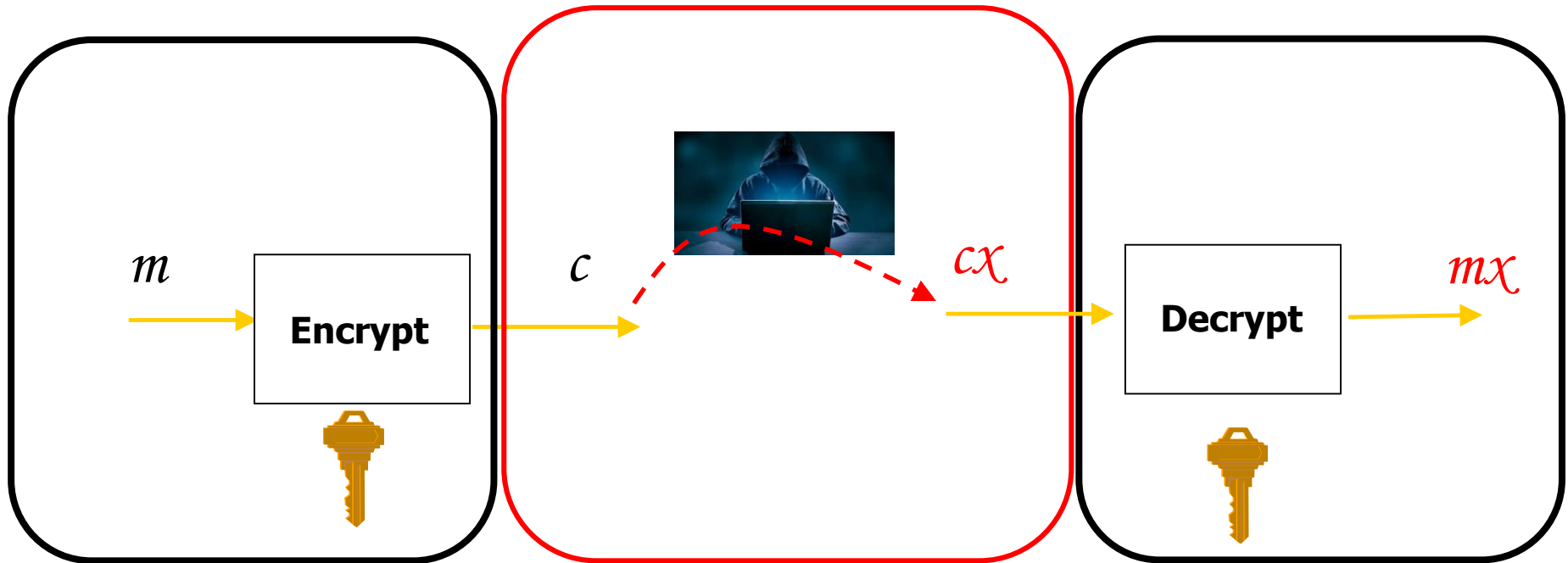
- ❑ Vennero in possesso di un esemplare della macchina
($\Rightarrow$ *conoscenza dell'algoritmo*)
- ❑ Scoprirono (anche sfruttando scoperte di matematici polacchi) che:
 - ❑ Con una "quantità sufficiente" di ciphertext
 - ❑ Molto spesso, si poteva diminuire enormemente il numero di chiavi da provare

Algoritmi moderni



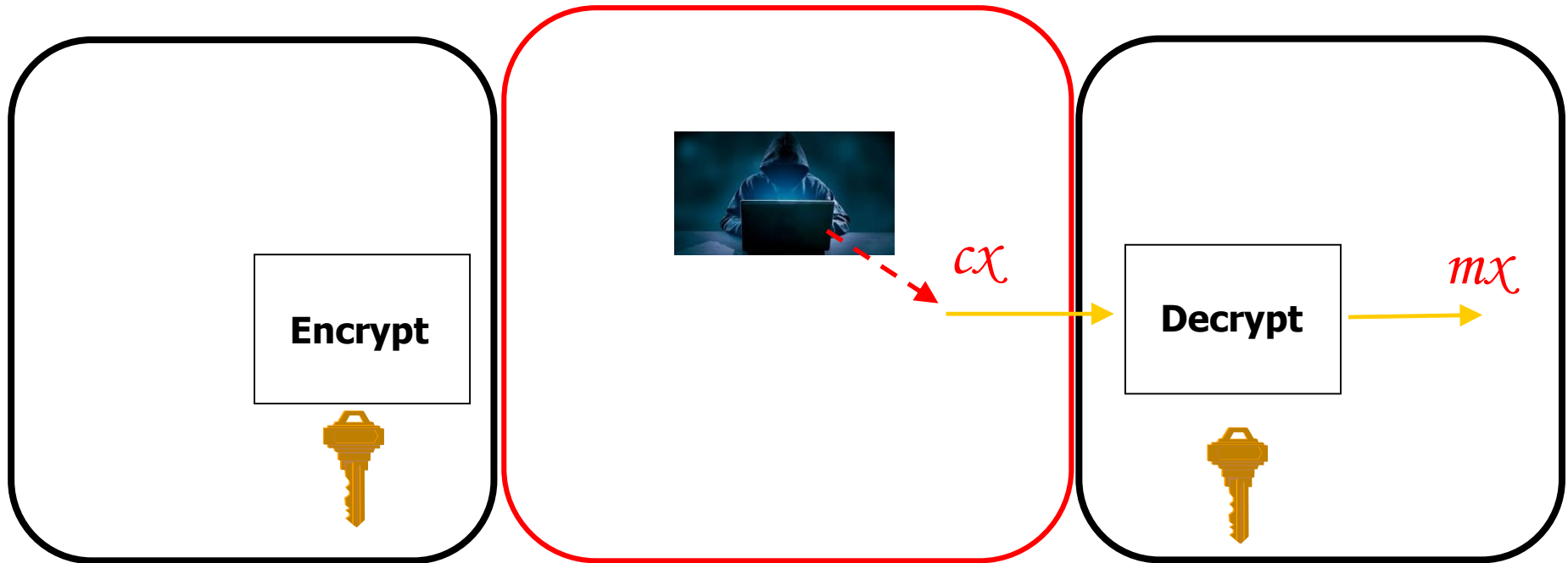
- ❑ **DES** Standard U.S. per informazioni non classificate.
Chiave di 56 bit.
- ❑ **DESX** DES modificato
- ❑ **Triple DES** Applica DES tre volte (con tre chiavi di 56 bit indipendenti).
Usato da molte istituzioni finanziarie
- ❑ **IDEA** Sviluppato e brevettato in Svizzera.
Chiave di 128 bit.
- ❑ **RC2, RC4, RC5** Sviluppati da RSA. Venduto con chiavi sino a 2048 bit.
- ❑ **AES**
- ❑ **Blowfish**
- ❑ ...

No Integrity



- ❑ Attacker non può sapere quale $m\chi$ produce...
- ❑ ...ma Ricevente non può rilevare la modifica

No Authentication



- ❑ Attacker non può sapere quale $m\chi$ produce...
- ❑ ...ma Ricevente non può determinare chi lo ha costruito

Secure Message Authentication Code (HMAC)



Osservazione



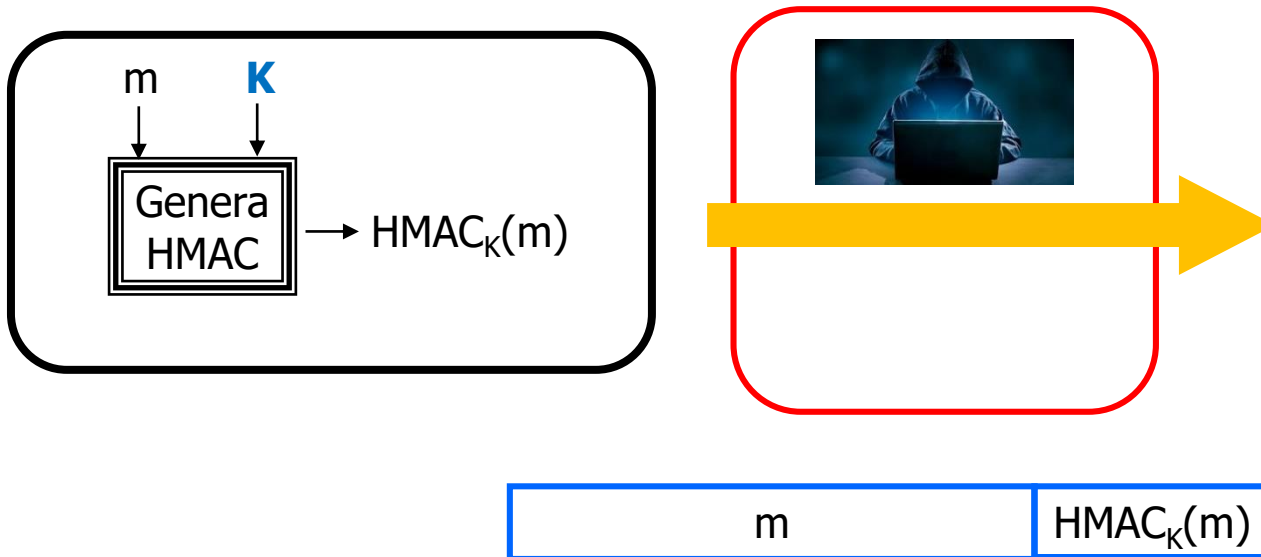
- ❑ Terminologia leggermente diversa da quella degli anni scorsi
- ❑ Più realistica
- ❑ (mi accontento anche della terminologia degli anni scorsi...MAC invece di HMAC)

Scenario



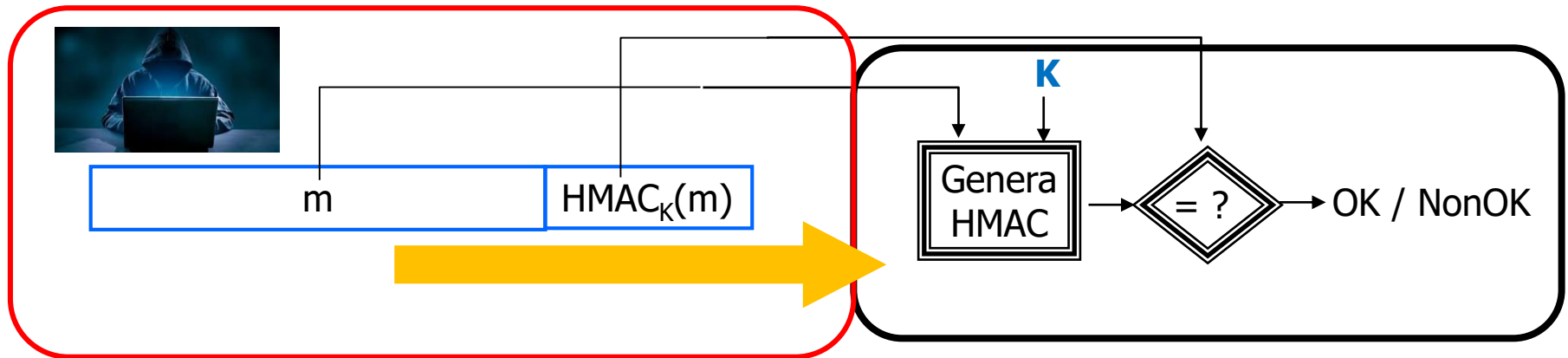
- ❑ Condividono chiave K
- ❑ Utilizzano K per garantire
 - ❑ **Autenticazione**
 - ❑ **Integrità**
- ❑ Possono usarla anche per Secrecy
- ❑ Ma è un procedimento indipendente da HMAC

Utilizzo: Sender



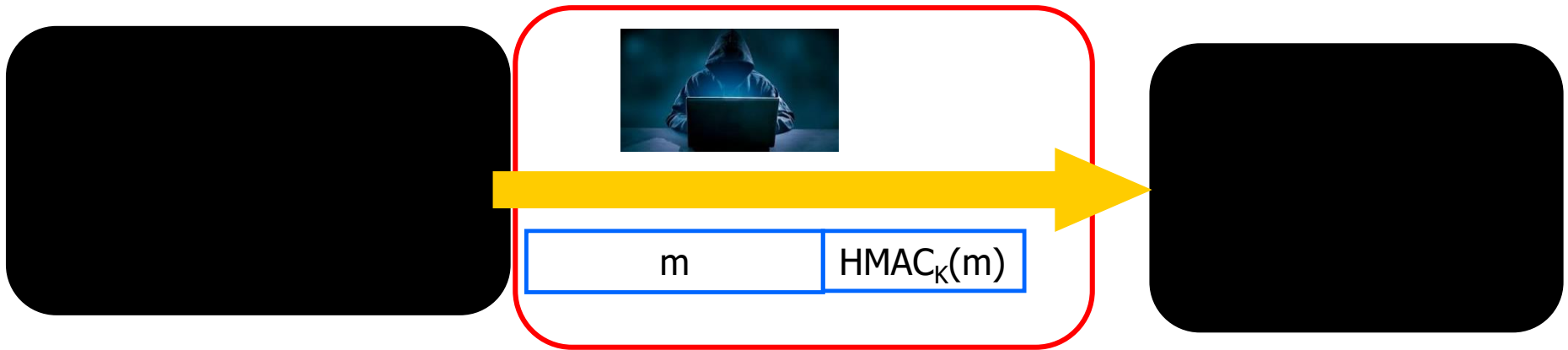
- ❑ $\text{HMAC}_K(m)$ ha lunghezza **fissa**
- ❑ Dipende dall'algoritmo e non da m

Utilizzo: Receiver



- ❑ OK $\Rightarrow$ $m, HMAC_K(m)$ sono
 - ❑ **Autentici** (Chi ha generato conosce K)
 - ❑ **Integri** (Non è stato alterato neanche un bit)
- ❑ Non-OK $\Rightarrow$ non sono autentici o non sono integri

Osservazione



- ❑ Il messaggio m è **in chiaro** (**non** garantisce secrecy)
- ❑ Se NetworkAttacker modifica, Receiver se ne accorge (**integrità**)
- ❑ Se NetworkAttacker genera, Receiver se ne accorge (**autenticazione**)

Distribuzione delle Chiavi



Obiettivo pratico



❑ Desideriamo:

- ❑ Riservatezza
- ❑ Autenticazione
- ❑ Integrità

❑ **Con Network Attacker**

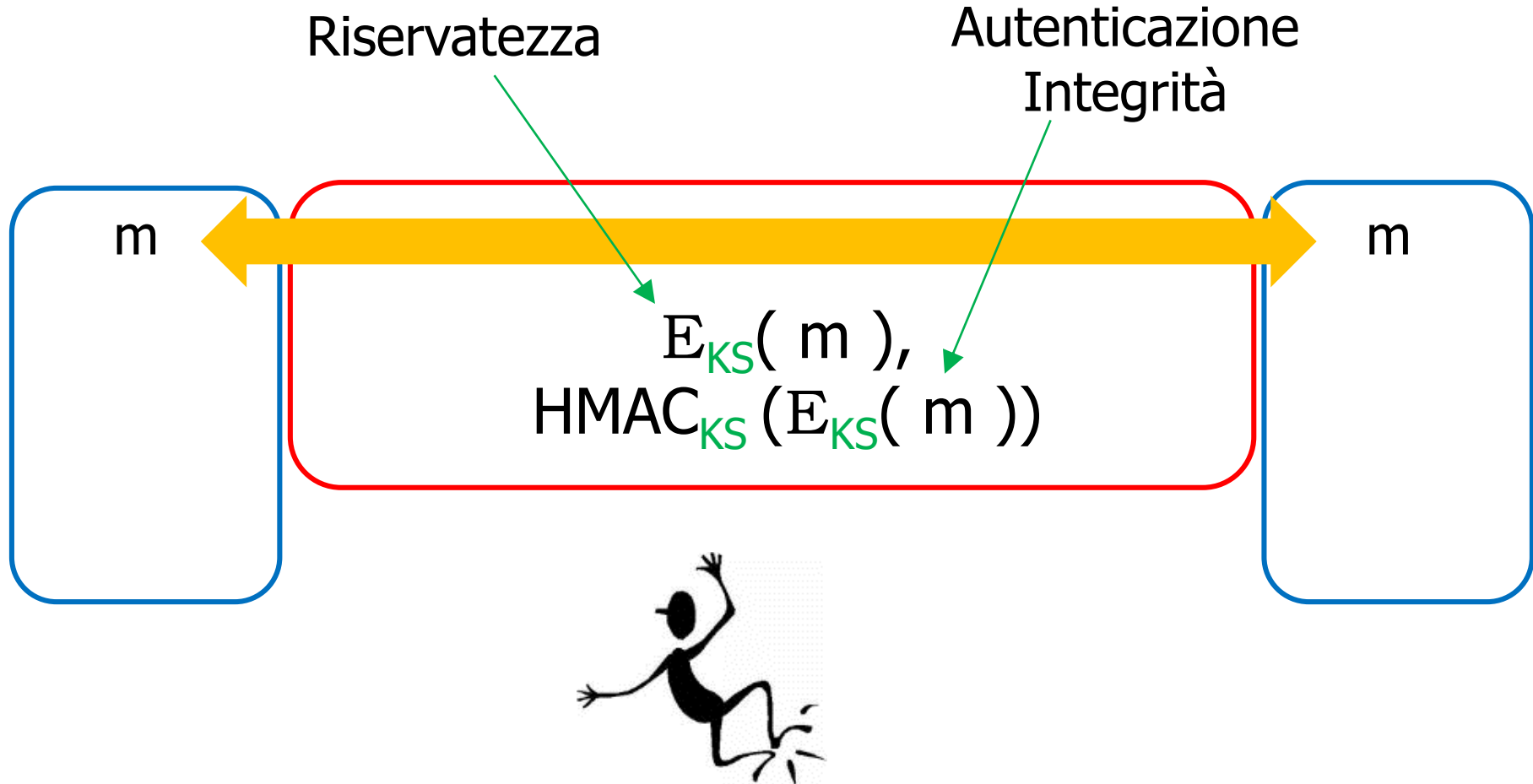
- | | | |
|-------------|---|----------------|
| ❑ Osserva | ⇒ | Riservatezza |
| ❑ Trasmette | ⇒ | Autenticazione |
| ❑ Modifica | ⇒ | Integrità |

Scenario di partenza

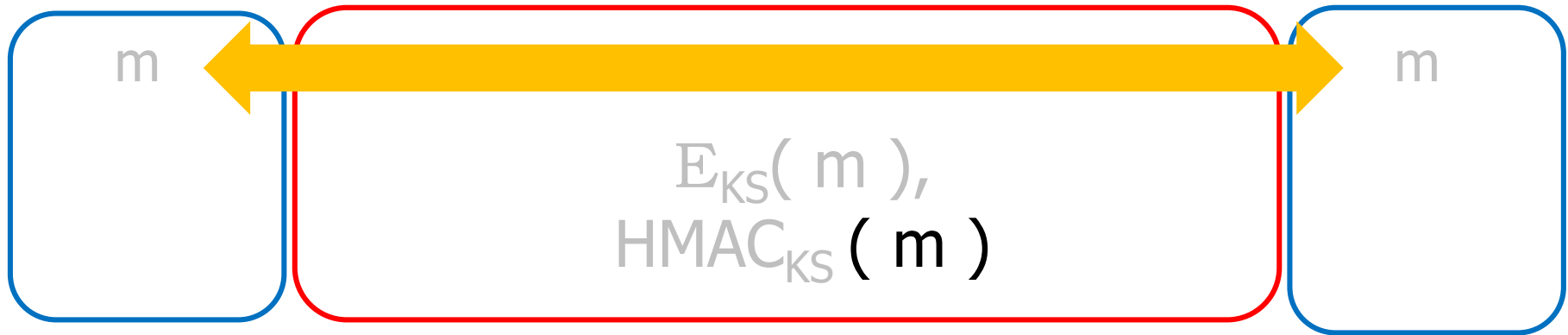


Chiave **KS** già condivisa

"E' fatta!"



Osservazione



- ❑ Al nostro livello di approfondimento potrebbe funzionare anche con $HMAC_KS(m)$
- ❑ Per motivi matematici & crittografici che non approfondiamo, in pratica si fa come nella slide precedente

Come realizzare lo Scenario di partenza?



Come fanno a scegliere **KS**???
Il canale non ha **nessuna**
proprietà di sicurezza!

Soluzione usata da secoli



- ❑ Canale AGGIUNTIVO sicuro tipico:
 - ❑ Incontro di persona
 - ❑ Valigetta diplomatica
 - ❑ Corriere sicuro (per definizione)
 - ❑ ...

Scambio chiavi su Canale aggiuntivo sicuro (I)

- ❑ Utilizzo **molto costoso**
- ❑ Latenza **molto elevata**
 - ❑ Se avessi un canale **sicuro economico** ed a **bassa latenza**
 - ❑ Allora la crittografia sarebbe inutile
- ❑ Necessario per **ogni coppia di Subject**
 - ❑ Ogni utente di Gmail, Gmail
 - ❑ Ogni utente di Facebook, Facebook
 - ❑ Ogni utente di BBVA Bank, BBVA Bank
 - ❑ ...

Scambio chiavi su Canale aggiuntivo sicuro (II)

In pratica:

□ Utilizzabile solo in **pochissime** applicazioni **molto specifiche**

1. **Poche** coppie di Subject
2. Note **a priori**
3. **Raramente** variabili

□ NON utilizzabile su Internet

- ~~1. Poche coppie di Subject~~
- ~~2. Note a priori~~
- ~~3. Raramente variabili~~

Potenzialmente **enorme**
Non noto a priori
Altamente **Dinamico**

"Crittografia quantistica" (QKD)



- Si basa sullo "scenario di partenza" (chiavi **già** distribuite)



- **Non** risolve il problema della **distribuzione delle chiavi** su Internet
 - Insieme di Subject **enorme**, **non** noto a priori, **dinamico**
- Provate ad implementare GMail (o qualsiasi altro sito web / smartphone app) con la crittografia quantistica
- ...o a crittare **un disco**

Crittografia chiave pubblica



Critt. chiave pubblica (I-a)

- ❑ Algoritmo crea **coppia** di chiavi K-PRIV-X, K-PUB-X
- ❑ **Casuale** ma con "alcune relazioni matematiche" tra le due chiavi
 - ❑ Dipendono dall'algoritmo
 - ❑ Non le vediamo
- ❑ Si chiamano:
 - ❑ K-PRIV-X: chiave **privata**
 - ❑ K-PUB-X: chiave **pubblica**
 - ❑ Vedremo il motivo della denominazione

Esempio coppia

Public Key 1 (243 bytes)

```
3081F03081A806072A8648CE38040130819C024100FCA682CE8E12CA
BA26EFCFF7110E526DB078B05EDECBCD1EB4A208F3AE1617AE01F35B
91A47E6DF63413C5E12ED0899BCD132ACD50D99151BDC43EE737592E
17021500962EDDCC369CBA8EBB260EE6B6A126D9346E38C502406784
71B27A9CF44EE91A49C5147DB1A9AAF244F05A434D6486931D2D1427
1B9E35030B71FD73DA179069B32E2935630E1C2062354D0DA20A6C41
6E50BE794CA40343000240598A4F6F3E48174A3F588DFD708B78F55A
8ED380C517D40DFD2714880983D0CCDE890F82EDB8233499D7A7C194
6C9B903879B3F5DB360640C5A1EE00F40A4322
```

Private Key 1 (201 bytes)

```
3081C60201003081A806072A8648CE38040130819C024100FCA682CE
8E12CABA26EFCFF7110E526DB078B05EDECBCD1EB4A208F3AE1617AE
01F35B91A47E6DF63413C5E12ED0899BCD132ACD50D99151BDC43EE7
37592E17021500962EDDCC369CBA8EBB260EE6B6A126D9346E38C502
40678471B27A9CF44EE91A49C5147DB1A9AAF244F05A434D6486931D
2D14271B9E35030B71FD73DA179069B32E2935630E1C2062354D0DA2
0A6C416E50BE794CA40416021453A7F56A7616BCCA9AFA7F46E5168F
37F69BEDBF
```

Critt. chiave pubblica (I-b)



- ❑ *Casuale ma con "alcune relazioni matematiche" tra le due chiavi*
- ❑ Lunghezza chiave N bit
- ❑ **Crittografia a chiave privata:**
 - ❑ **Ogni** naturale di N bit può essere una chiave
- ❑ **Crittografia a chiave pubblica:**
 - ❑ **Solo alcune** coppie di numeri a N bit possono essere usate come chiavi

Scenario di partenza

KPUB-X



KPUB-X



...

KPUB-X



Chiave pubblica
già distribuita

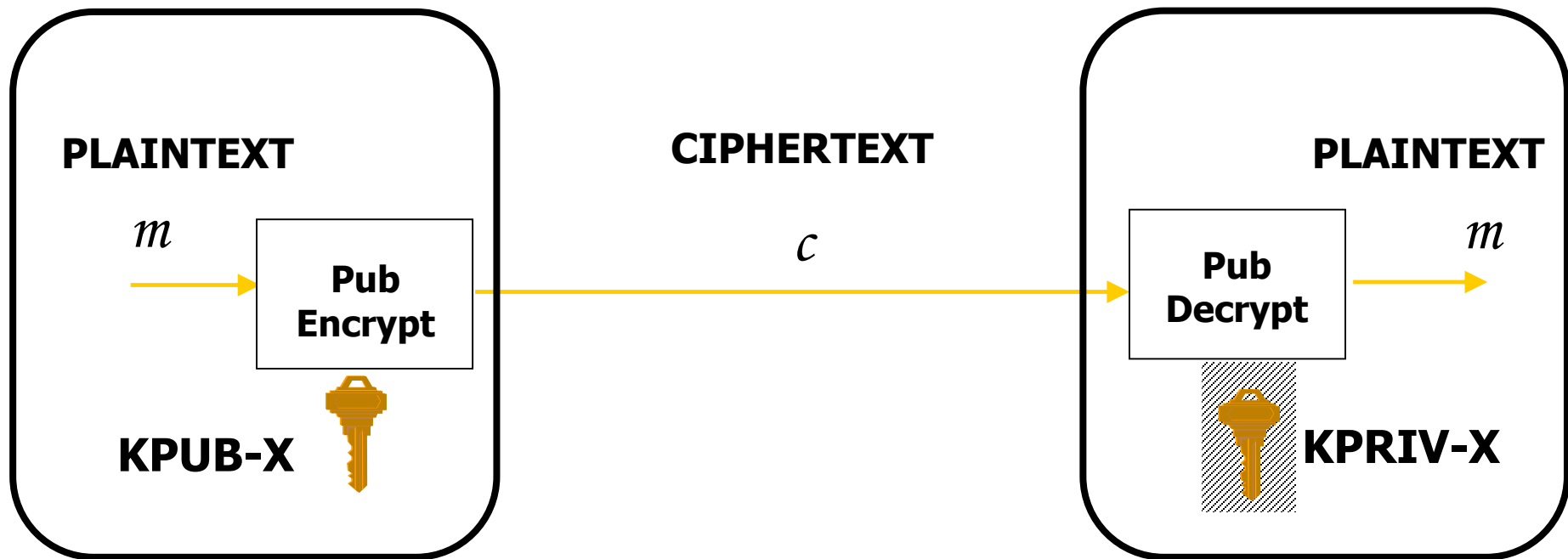


KPRIV-X



KPUB-X

Crittografia a chiave pubblica (II)



Crittografia a chiave pubblica (III)

□ Notazione:

□ Coppia di chiavi: $K\text{-PUB-}x$ $K\text{-PRIV-}x$

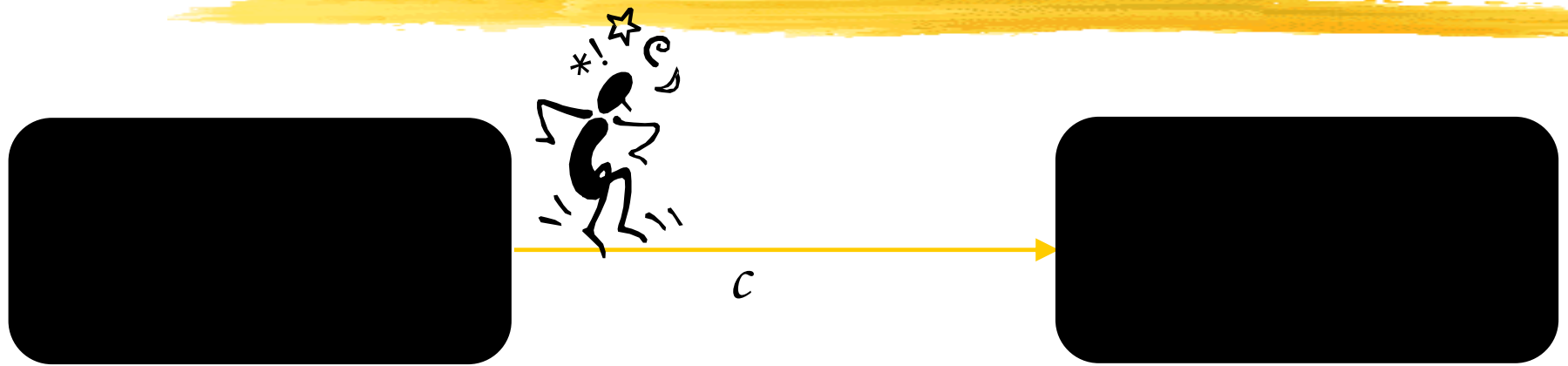
□ Critto: $\text{PubEncrypt}_{K\text{-PUB-}x}(m)$

□ Decritto: $\text{PubDecrypt}_{K\text{-PRIV-}x}(c)$

$$\begin{array}{c} \xleftarrow{c} \\ \square \text{PubDecrypt}_{K\text{-PRIV-}Y}(\text{PubEncrypt}_{K\text{-PUB-}X}(m)) = m \\ \Leftrightarrow \\ K\text{-PRIV-}Y = K\text{-PRIV-}X \end{array}$$

□ "Per risalire al plaintext serve la chiave privata giusta (la compagna della chiave pubblica usata per crittare)"

Proprietà fondamentale (in parole povere)



❑ PRATICAMENTE IMPOSSIBILE:

- ❑ $K_{PUB-X} \rightarrow K_{PRIV-X}$
- ❑ Ciphertext $\rightarrow K_{PRIV-X}$
- ❑ Ciphertext $\rightarrow$ Plaintext

❑ L'algoritmo e K_{PUB-X} non sono segreti!

Al solito...



- ❑ Algoritmi moderni:
 - ❑ "Sono troppe"
 - ❑ "Devo provarle tutte"

Algoritmi moderni



Inventati nel **1976** (Diffie e Hellman, Markle)

- ❑ **RSA** Rivest, Shamir, Adleman. Può usare chiavi di lunghezza qualsiasi.
- ❑ **DSS** Serve sia per crittografia che per “digital signature”. Standard US. Può funzionare con chiavi di qualsiasi lunghezza, ma lo standard US permette solo chiavi tra 512 bit e 1024 bit.
- ❑ **El Gamal**
- ❑ ...

Poi si è scoperto che uno studente li aveva inventati prima di loro in un tirocinio estivo al GCHQ ma non lo poteva dire...

Osservazione (I)



- ❑ Il termine “**chiave privata**” può generare ambiguità
- ❑ Nessuna parentela tra:
 - ❑ Crittografia a chiave privata
 - ❑ “Chiave privata” della Crittografia a chiave pubblica
- ❑ Sono **algoritmi completamente diversi**

Osservazione (II)



- ❑ **Molto più lenta di crittografia a chiave privata**
(da 10 a 100 volte)
- ❑ Stessa sequenza di byte
- ❑ Tempo superiore di uno o due ordini di grandezza

Terminologia



- ❑ Crittografia a chiave pubblica:
 - ❑ A chiave **asimmetrica**

- ❑ Crittografia a chiave privata:
 - ❑ A chiave **simmetrica**
 - ❑ A chiave **segreta**
 - ❑ A chiave **condivisa** (shared)

Distribuzione delle Chiavi (II)



Obiettivo pratico (REMINDE)



❑ Desideriamo:

- ❑ Riservatezza
- ❑ Autenticazione
- ❑ Integrità

❑ **Con Network Attacker**

- | | | |
|-------------|---|----------------|
| ❑ Osserva | ⇒ | Riservatezza |
| ❑ Trasmette | ⇒ | Autenticazione |
| ❑ Modifica | ⇒ | Integrità |

Scenario di partenza

KPUB-X



KPUB-X



...

KPUB-X



Chiave pubblica
già distribuita

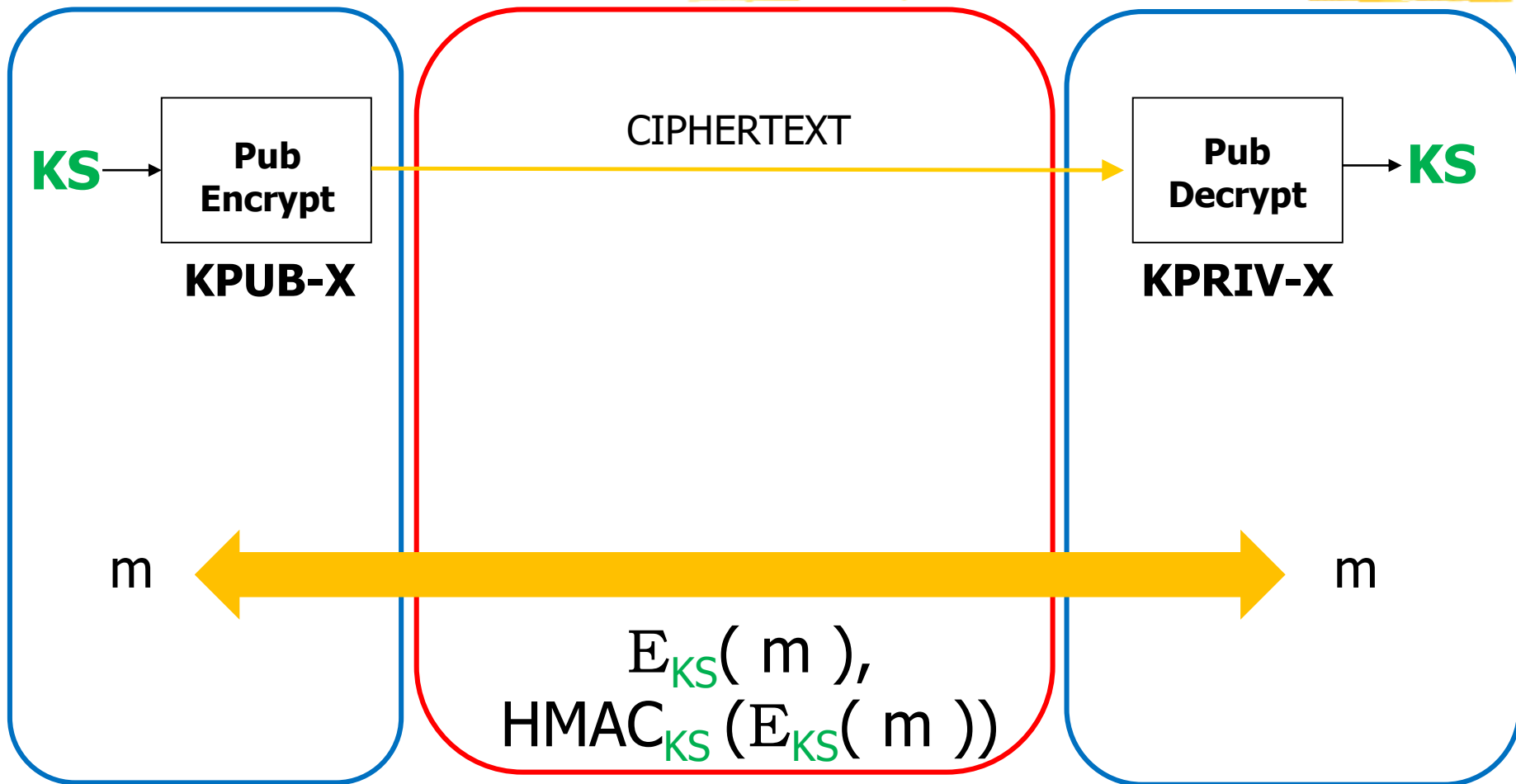


KPRIV-X



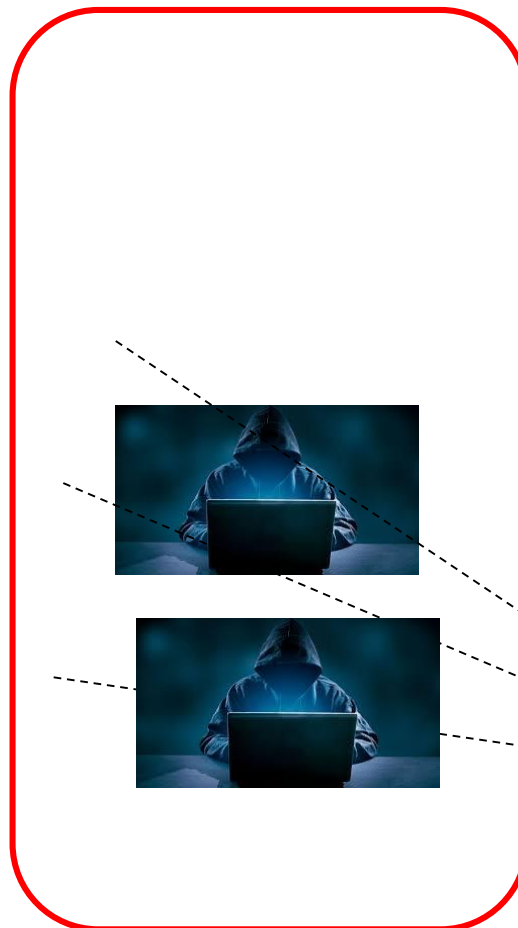
KPUB-X

"E' fatta!" (sembra...)

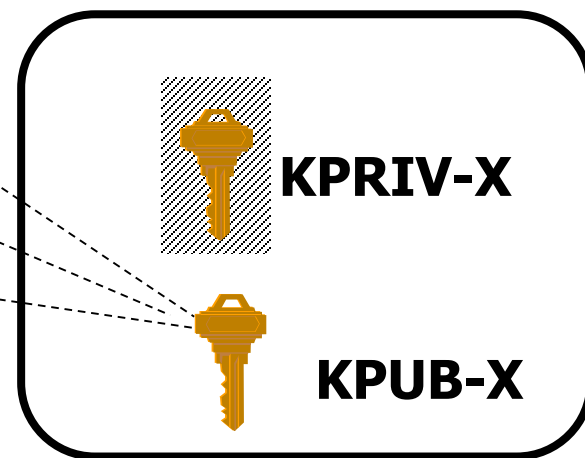


Come realizzare lo Scenario di partenza?

...



Il canale non ha **nessuna** proprietà di sicurezza!



Problema FONDAMENTALE (I)

*Devo comunicare
con Unicredit*

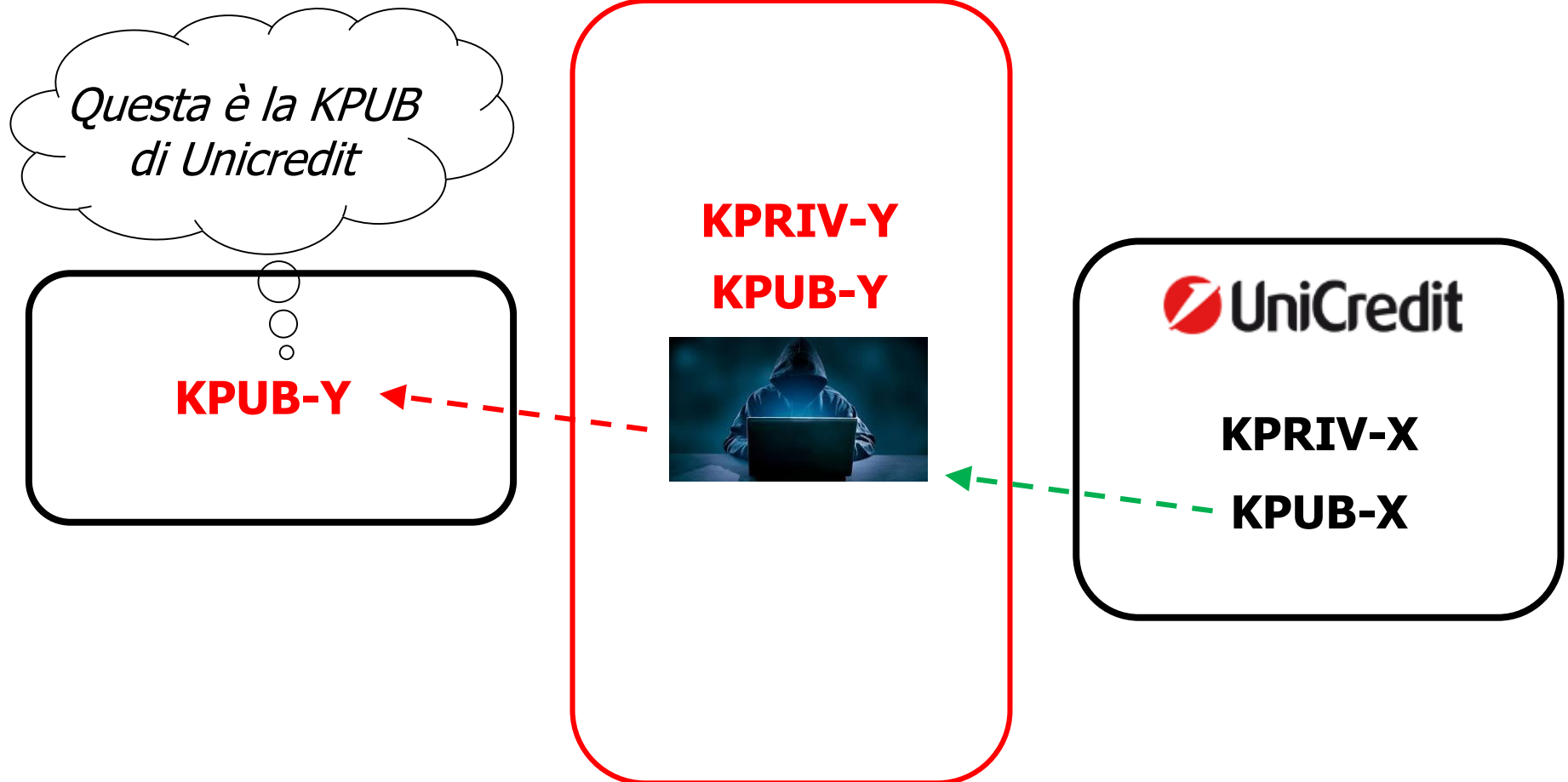
KPRIV-Y
KPUB-Y



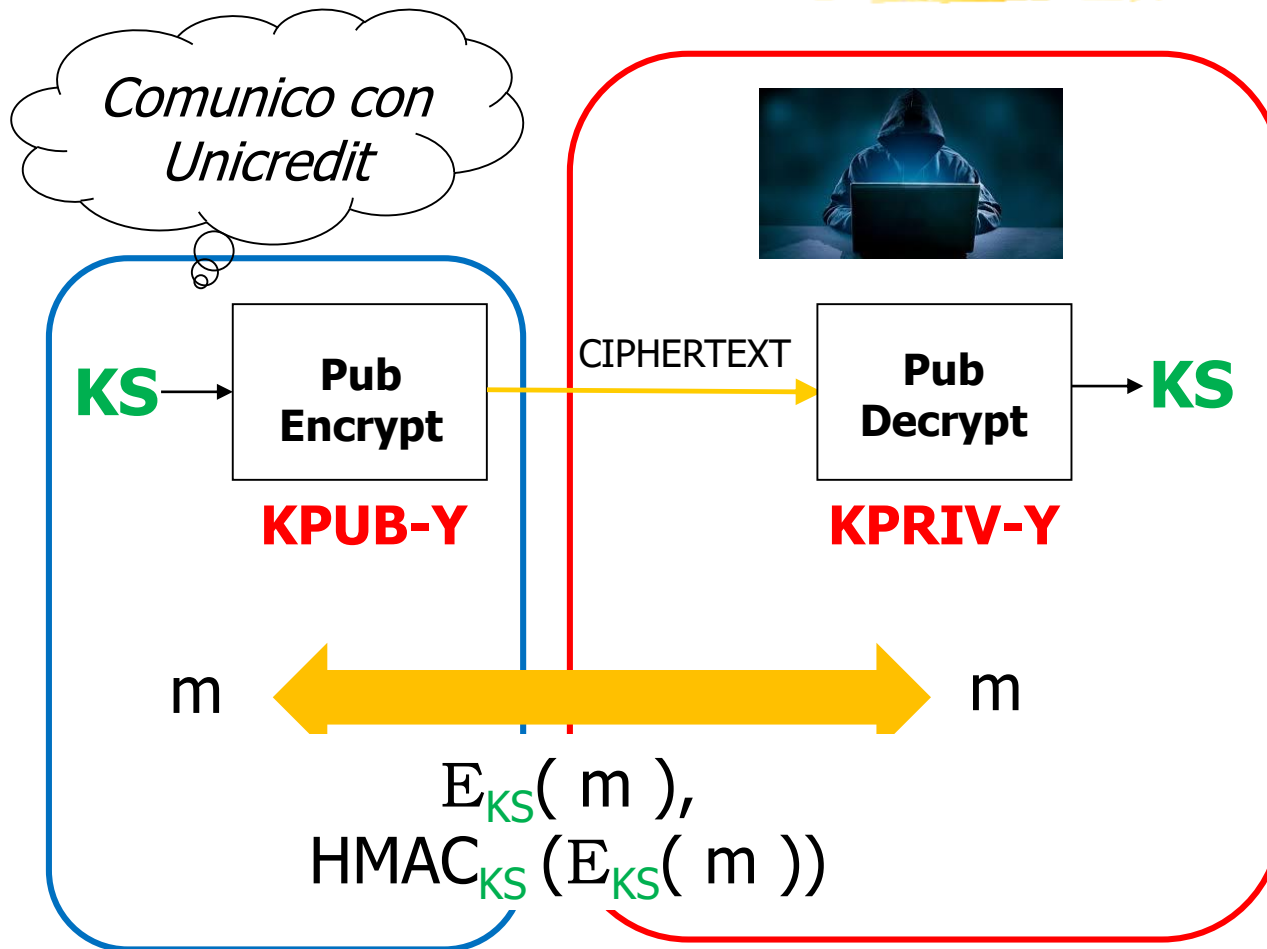
 **UniCredit**

KPRIV-X
KPUB-X

Problema FONDAMENTALE (II)



Problema FONDAMENTALE (III)



E quindi?

- ❑ Devo comunicare su canale **non sicuro**
- ❑ Uso crittografia per renderlo **sicuro**

- ❑ Per usare crittografia devo avere delle chiavi
- ❑ Come le distribuisco?
 - ❑ Sul canale **non sicuro**: Non posso (ovviamente)
 - ❑ Su un canale **sicuro** aggiuntivo: Non è fattibile

- ❑ Problema che esiste da secoli



Cyberchef / Google Colab Notebook



- ☐ Cyberchef – Private key crypto - OPTIONAL
- ☐ Cyberchef – Public key crypto - OPTIONAL
- ☐ Colab Notebook: Crypto – No subject
- ☐ Suggerisco l'ordine indicato